

Name: Nelay Sharma
University ID: #122295414
Directory ID: nsharm21
Course: ENPM634
Date: 5/9/2026

King of the Hill Retrospective

1.1 Network Size

The /24 subnet (10.151.2.0/24) contained 6 live hosts. The KOTH target was 10.151.2.123 running a Flask/Gunicorn application as its primary vulnerable service endpoint.

1.2 Important Boxes

The important boxes were: 151.2.123 (i.e., KOTH target, MarketReach Analytics portal), 10.151.2.1 (i.e., gateway/DNS infrastructure and name resolution), 10.151.2.55 (i.e., web plus MySQL), 10.151.2.92 (i.e., Tomcat), 10.151.2.226 (i.e., multi-service hub for email, file transfer, and web services).

1.3 Three Attacks

- **SSRF on /fetch?url=** - Read local files and internal endpoints, exposing app source code, hardcoded credentials, and HMAC tokens.
- **IDOR on /api/users/<id>** - Authenticated as appadmin and enumerated hidden user ID 99 to retrieve flag E2.
- **Credential Reuse** - SSH as developer using leaked password Spring2024! to attempt KOTH script injection (i.e., blocked by defensive persistence).

1.4 Defense

The previous team secured the KOTH via immutable file bits, which is a cron script running every minute to reclaim with their token for automatic persistence and reclamation, and then process-killing to eliminate competing attempts. My team couldn't override it as the immutable bit prevented file modification, with insufficient privilege escalation vectors available.

1.5 Security Fixes

- **SSRF Protection** - Whitelist allowed schemes/hosts; reject file://, localhost, and private IPs using URL validation.
- **IDOR & Credentials** - Move hardcoded secrets to environment variables; implement per-user authorization checks; use UUIDs instead of sequential IDs.

1.6 Conclusion & Experience

The lab taught us chained **SSRF→IDOR→privilege escalation** in a realistic post-acquisition scenario, especially as the KOTH mechanic taught defensive persistence. The only improvements I see with this lab is it should provide clearer escalation paths post-foothold, include defensive playbook hints, and implement reset windows in multi-hour events.